

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

CHECKLIST NOTIFICHE NIS2

Area 08 – Sistema Informativo

Codice	Revisione	Data	Pagine
TD-SGI-MOD184_00	00	29/04/2026	4
Redatto da	Approvato da	Classificazione	Stato
RSGI	AD – Francesco Epifani	Riservato Alta Direzione + ACN	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
29/04/2026	29/04/2026	29/04/2026

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

1. Scopo

La presente checklist supporta operativamente il Punto di Contatto NIS nella gestione delle tre finestre di notifica obbligatorie ai sensi dell'art. 25 c. 4 del D.Lgs. 138/2024 — pre-allerta entro 24 ore, notifica intermedia entro 72 ore, relazione finale entro 30 giorni dalla conoscenza dell'evento — e nelle eventuali notifiche multi-autorità (Garante Privacy, Ministero della Salute, OdV 231).

La checklist è da compilare integralmente per ogni incidente significativo o grave registrato nel TD-SGI-MOD181 (Registro Incidenti). Ogni voce può essere marcata SI / NO / N.A. con note. Le voci non spuntate o marcate NO devono essere giustificate per iscritto al §4.

2. Anagrafica incidente

Voce	Dato
ID Incidente (cfr. MOD181)	NIS-2026-####
T0 (data e ora di conoscenza)	gg/mm/aaaa hh:mm
Significatività dichiarata	Significativo / Grave
Categoria (cfr. MOD181 §3)	—
Sistemi impattati	—
PdC NIS responsabile della notifica	AD – Francesco Epifani
Sostituto attivato	Sì/No, motivazione

3. Checklist per finestra di notifica

3.1 Pre-allerta entro T0+24 ore al CSIRT Italia tramite Portale ACN

#	Verifica	SI/NO/N.A.	Note
1	L'incidente è classificato come significativo/grave secondo §3 PRO070?		
2	È stato aperto il fascicolo evidenze nel SGI con id NIS-yyyy-####?		
3	Sono stati raccolti i log e gli artefatti tecnici minimi?		
4	È stata effettuata l'autenticazione sul Portale ACN con account PdC NIS?		
5	Sono stati compilati i campi minimi della pre-allerta (descrizione, T0, sistemi, perimetro stimato)?		
6	È stata identificata l'eventuale natura dolosa/illegittima dell'evento?		
7	È stata stimata la propagazione transfrontaliera (impatto su servizi UE)?		
8	L'AD/Legale Rappresentante è stato informato per la sottoscrizione?		
9	La pre-allerta è stata trasmessa entro T0+24h?		
10	È stato registrato l'ID Portale ACN della trasmissione nel MOD181?		

3.2 Notifica intermedia entro T0+72 ore al CSIRT Italia tramite Portale ACN

#	Verifica	SI/NO/N.A.	Note
1	Le informazioni della pre-allerta sono state confermate o rettificate?		

2	È stata effettuata una valutazione iniziale di gravità (impatto, propagazione, vettore)?		
3	Sono state documentate le azioni di contenimento adottate fino a T0+72h?		
4	È stata verificata la compromissione di dati personali (data breach GDPR)?		
5	In caso di data breach, è stata gestita la notifica al Garante Privacy entro 72h art. 33 GDPR?		
6	È stato comunicato in via cautelativa al Direttore Sanitario per impatto su pazienti?		
7	È stata aperta interlocuzione con OdV 231 se l'evento può configurare un cyber-reato?		
8	La notifica intermedia è stata trasmessa entro T0+72h?		
9	È stato aggiornato il MOD181 con esito e timestamp?		

3.3 Relazione finale entro T0+30 giorni al CSIRT Italia tramite Portale ACN

#	Verifica	SI/NO/N.A.	Note
1	L'analisi delle cause root (RCA) è stata completata?		
2	Le azioni correttive (CAPA) sono state pianificate con owner e scadenze?		
3	L'impatto economico e reputazionale è stato stimato?		
4	L'impatto sui pazienti è stato stimato (numero, tipologia, gravità)?		
5	Sono state classificate le minacce in tassonomia ENISA?		
6	La relazione finale è stata trasmessa entro T0+30gg?		
7	Sono stati aggiornati gli SOA / DPIA / inventario asset / threat model?		
8	La chiusura formale è stata sottoscritta da PdC NIS + AD?		
9	Il fascicolo evidenze è stato consolidato nell'archivio digitale del SGI?		
10	Sono state programmate sessioni di lessons learned?		

4. Notifiche multi-autorità collaterali

Autorità	Trigger di notifica	Termine	Effettuata?	Riferimento
Garante per la protezione dei dati personali	Data breach con probabile rischio per i diritti degli interessati	72 ore (art. 33 GDPR)		
Garante Privacy — comunicazione agli interessati	Rischio elevato per gli interessati	Senza ingiustificato ritardo (art. 34 GDPR)		
Ministero della Salute / Regione Toscana	Sospensione di servizi diagnostici per il SSN	Senza ingiustificato ritardo		
Carabinieri / Polizia Postale e Comunicazioni	Sospetto cyber-reato	Senza ingiustificato ritardo		
OdV 231 (interno)	Possibile illecito ex Catalogo 231	Entro 5 giorni lavorativi		

DPO (interno)	Qualsiasi data breach	Entro 24 ore		
CdA / Alta Direzione	Incidenti significativi/gravi	Entro 24 ore		
Assicurazione Cyber	Incidenti che attivano polizza	Entro le 48-72 ore (verifica condizioni polizza)		

5. Giustificazioni delle voci non spuntate

[Compilare in caso di NO o N.A. nelle precedenti checklist. Le motivazioni devono essere oggettive e tracciabili.]

6. Sottoscrizioni

Punto di Contatto NIS

RSGI

AD – Francesco Epifani

Iacopo Cupelli

Firma: _____

Firma: _____

Data: ____/____/____

Data: ____/____/____

7. Storico delle revisioni

Rev.	Data	Descrizione	Redatto	Approvato
00	29/04/2026	Prima emissione della checklist notifiche NIS2 in attuazione di TD-SGI-PRO070_00 §6.	RSGI	AD